HCML Monitoring Portal: sign-in, session, renewal and sign-out

Browser
nginx
Server

1. POST /bff/api/auth/login with name, password and the X-HCML-CSRF header
2. POST /api/auth/login, with a request id added
3. check the header and the Origin, then the per-account limit and any lock
4. look the name up and check the scrypt hash, with a decoy check for an unknown name
5. 200 and a session cookie (HttpOnly, SameSite Strict), plus the seconds it lasts

every later request carries the cookie

6. GET /api/problems
7. verify the signature, the issuer and the epoch, then look the user up again
8. compare the current role with the rule for the route
9. 200 with data, or 401 sign in, or 403 wrong role
10. POST /api/auth/refresh, an hour before the end
11. a new cookie
12. POST /api/auth/logout
13. cookie cleared, and the old token is refused from then on

Browser
nginx
Server